

Simtec Consult - Secure Software Development Policy

Version: 1.0

Status: Approved

Owner: Director

Applies to: software development, maintenance, deployment, customer application work

Related to: Cyber Essentials, UK Government Software Security Code of Practice

Last reviewed: 2026-06-03

Next review due: 2026-09-03

Purpose

Simtec develops and maintains software for customers. This policy sets secure design, source control, secrets, dependency, build, deployment, and maintenance expectations.

Policy

Projects should consider security from the start, including authentication, authorisation, least privilege, data minimisation, personal data protection, secure defaults, secrets management, logging, dependency risk, backup and restore needs, and customer security requirements.

GitHub is used for source control. Controls must include named accounts, MFA, role-based repository access, access limited to project need, prompt access removal, no secrets committed to repositories, and branch protection or review controls where appropriate for project risk.

Secrets include passwords, API keys, tokens, SSH keys, private keys, and deployment credentials. Secrets must be stored in approved password, secret, or environment management tooling, not committed to source control, limited to minimum access, rotated if exposed or no longer needed, and separated between development, staging, and production where practical.

Projects should use supported dependencies from trusted sources. High-risk or critical dependency vulnerabilities must be reviewed and fixed promptly based on risk. Where software is in Cyber Essentials scope, high-risk and critical fixes should be prioritised within 14 days.

Build and deployment systems must use named accounts, MFA where available, least-privilege deployment access, protected production credentials, and access review when staff, contractors, or projects change.

Security review should be proportionate to project risk. This may include code review for authentication, authorisation and data handling changes, dependency scanning, configuration review, exposed port review, admin route review, cloud permission review, and manual testing of sensitive workflows.

Where Simtec supplies or maintains software for customers, it must communicate security-relevant release notes, required customer configuration changes, known vulnerability remediation steps, incident or breach notifications required by contract or law, and end-of-support warnings where relevant.

Unsupported software, dependencies, or hosting used in customer or internal systems must be assessed, upgraded, replaced, retired, or recorded as accepted risk by a Director.

Review

This policy is reviewed annually and when development, hosting, deployment, or customer support processes materially change.

Review History

Date	Reviewer	Description	Next review due
2026-06-03	Policy Manager	Created current policy document aligned to Simtec requirements and relevant Cyber Essentials answers.	2026-09-03